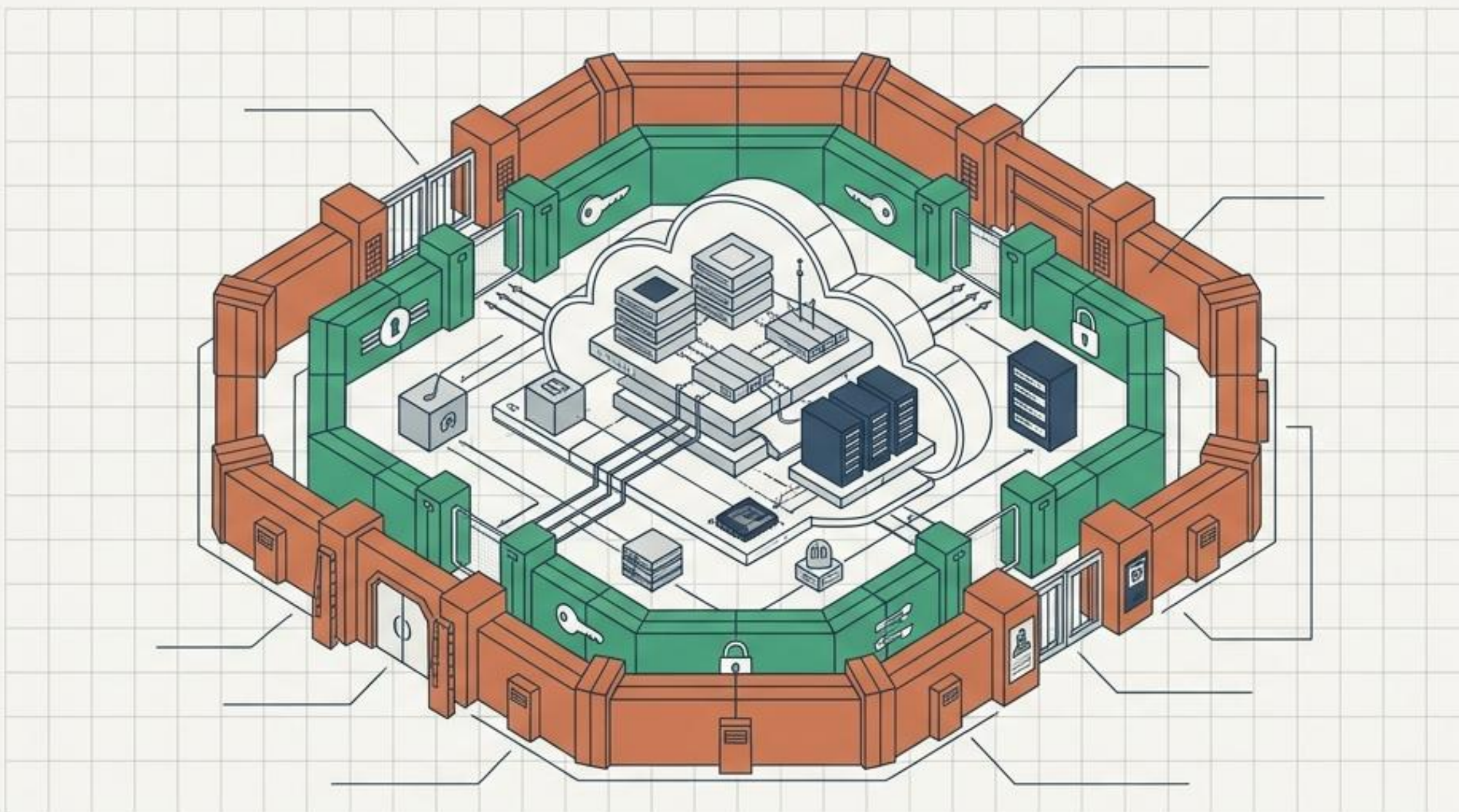


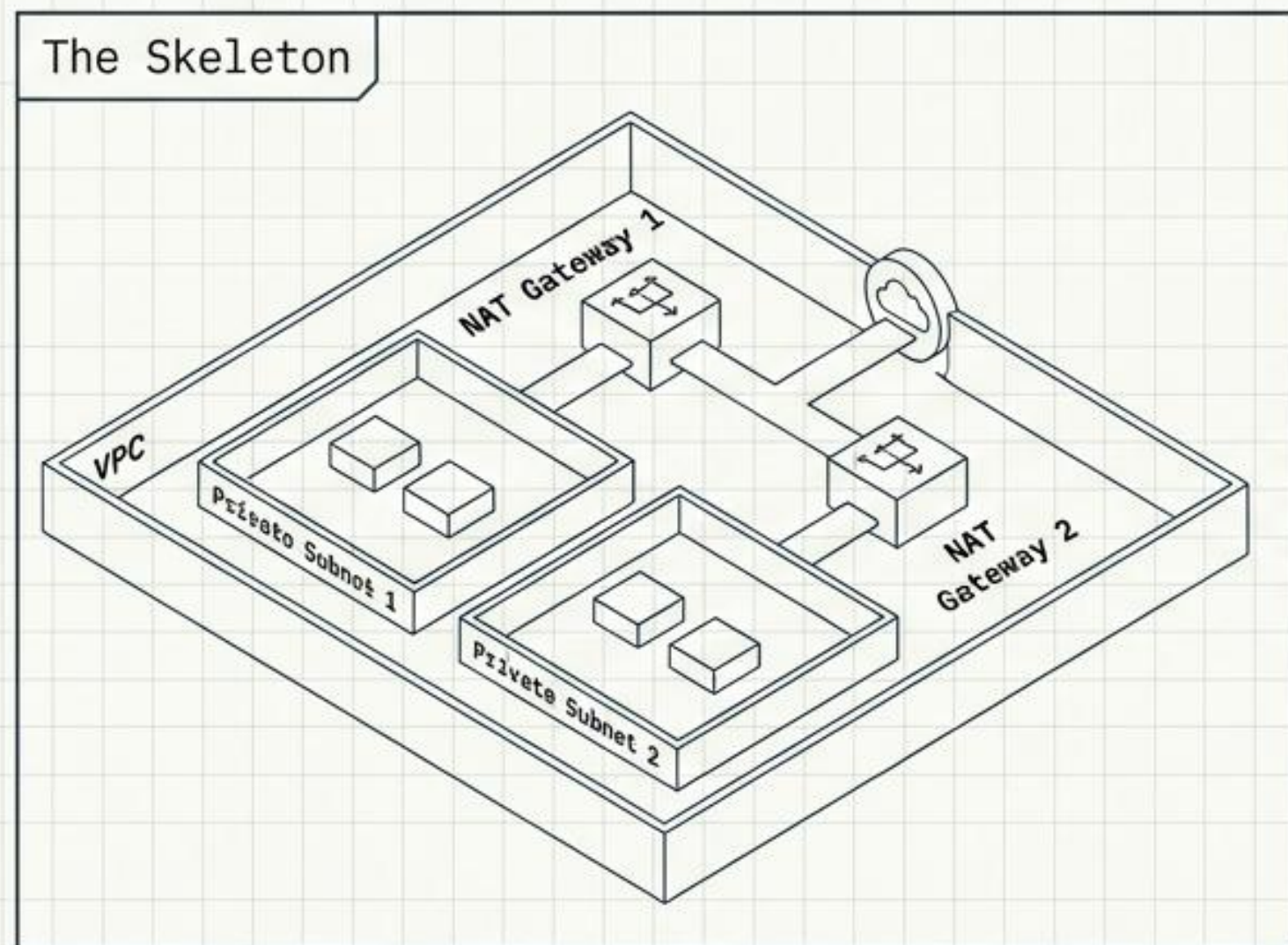


Arquitetura de Segurança Cloud

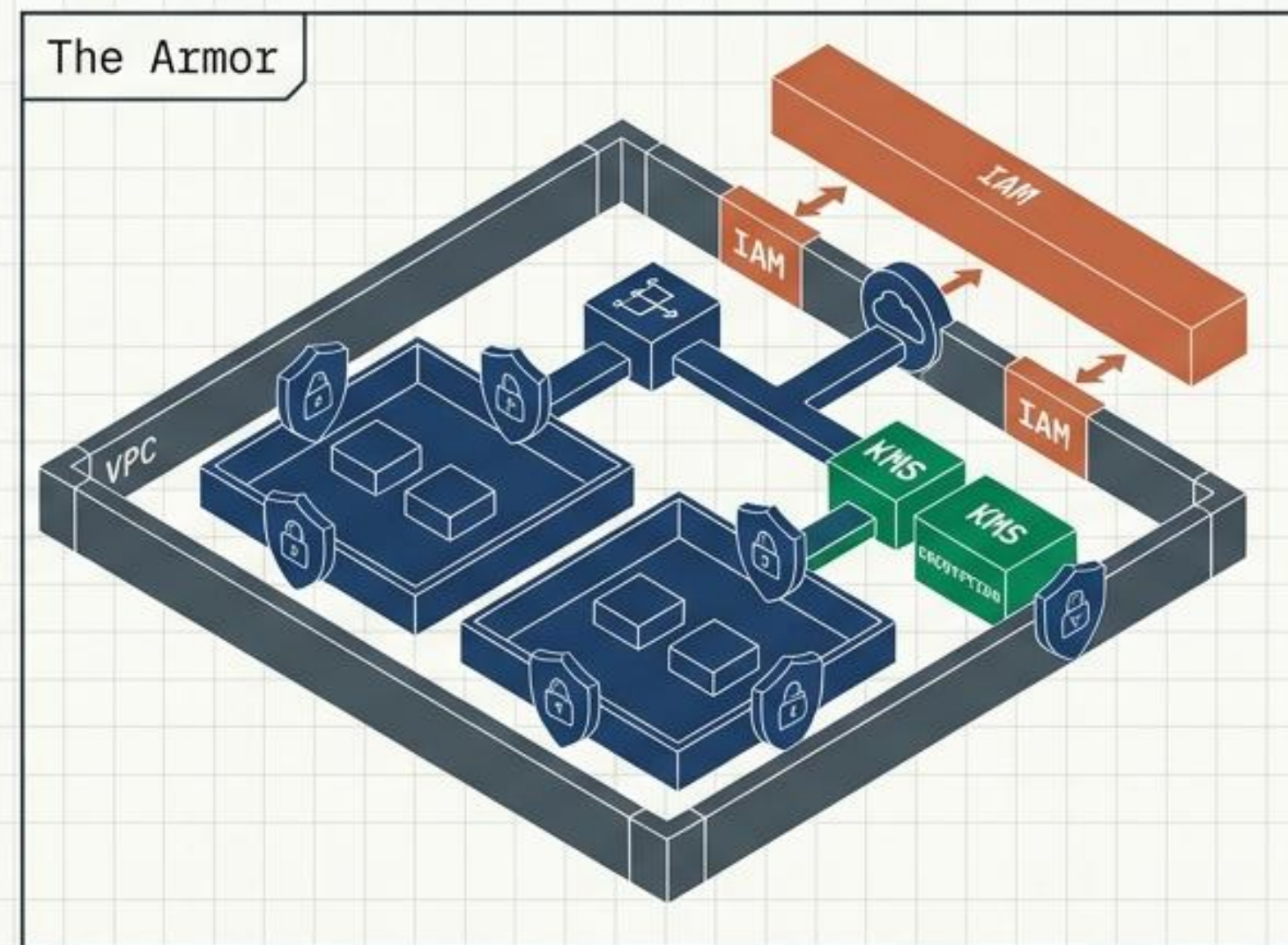
Do design de infraestrutura à conformidade legal e defesa em profundidade.

Case Prático: SwiftTrack IoT

A evolução da arquitetura base para o ambiente seguro

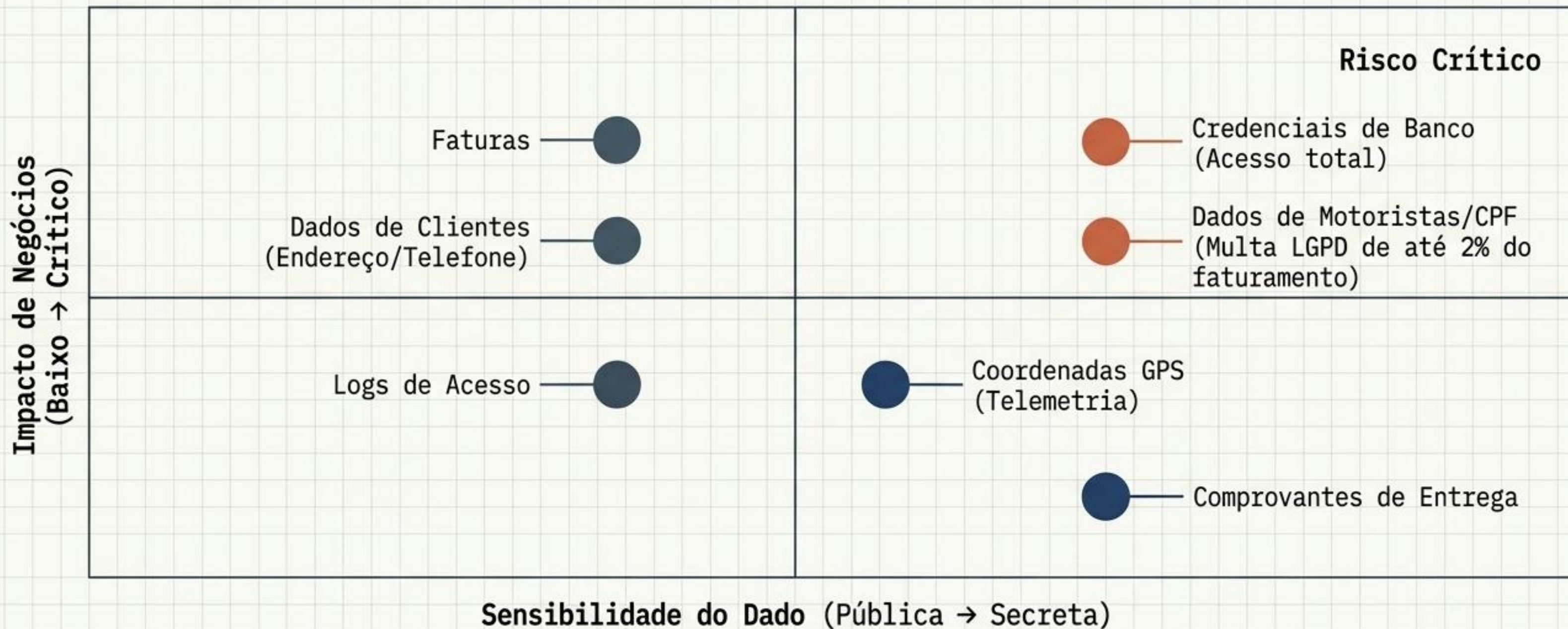


A Rede: Criação do perímetro básico. Sub-redes isoladas e rotas configuradas.



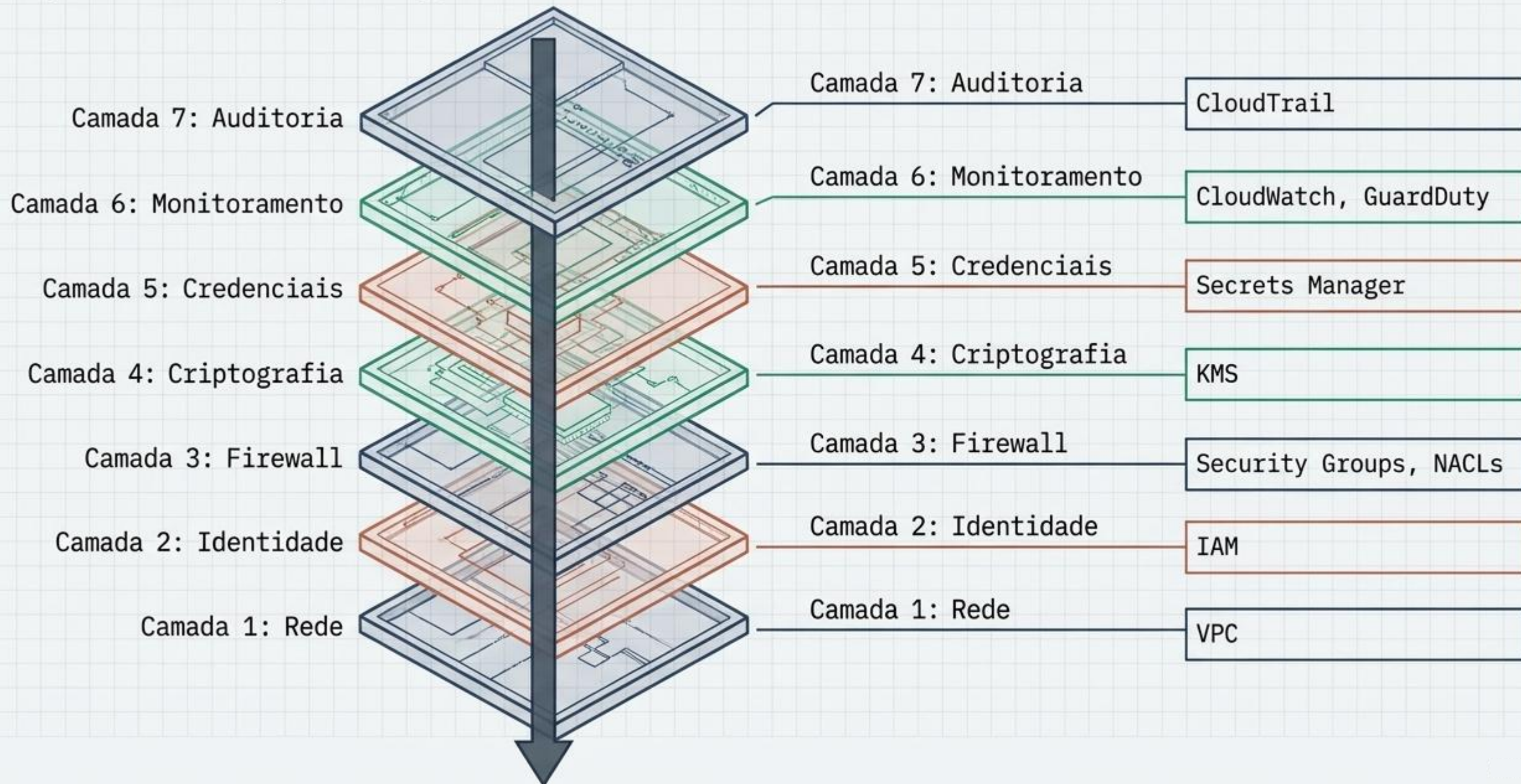
A Segurança: Políticas granulares, criptografia obrigatória e proteção de segredos.

O tabuleiro de riscos da SwiftTrack IoT

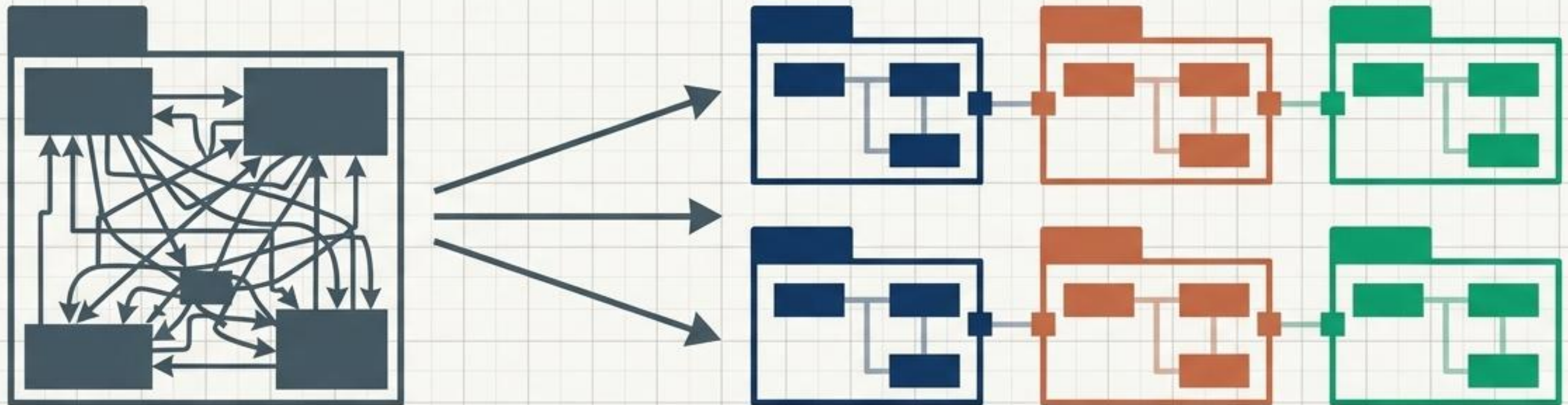


A perda de dados pessoais não é apenas uma falha técnica, mas uma violação regulatória imediata.

Se uma camada falhar,
a próxima protege o ativo



O Modelo de Análise estrutura a complexidade através de pacotes



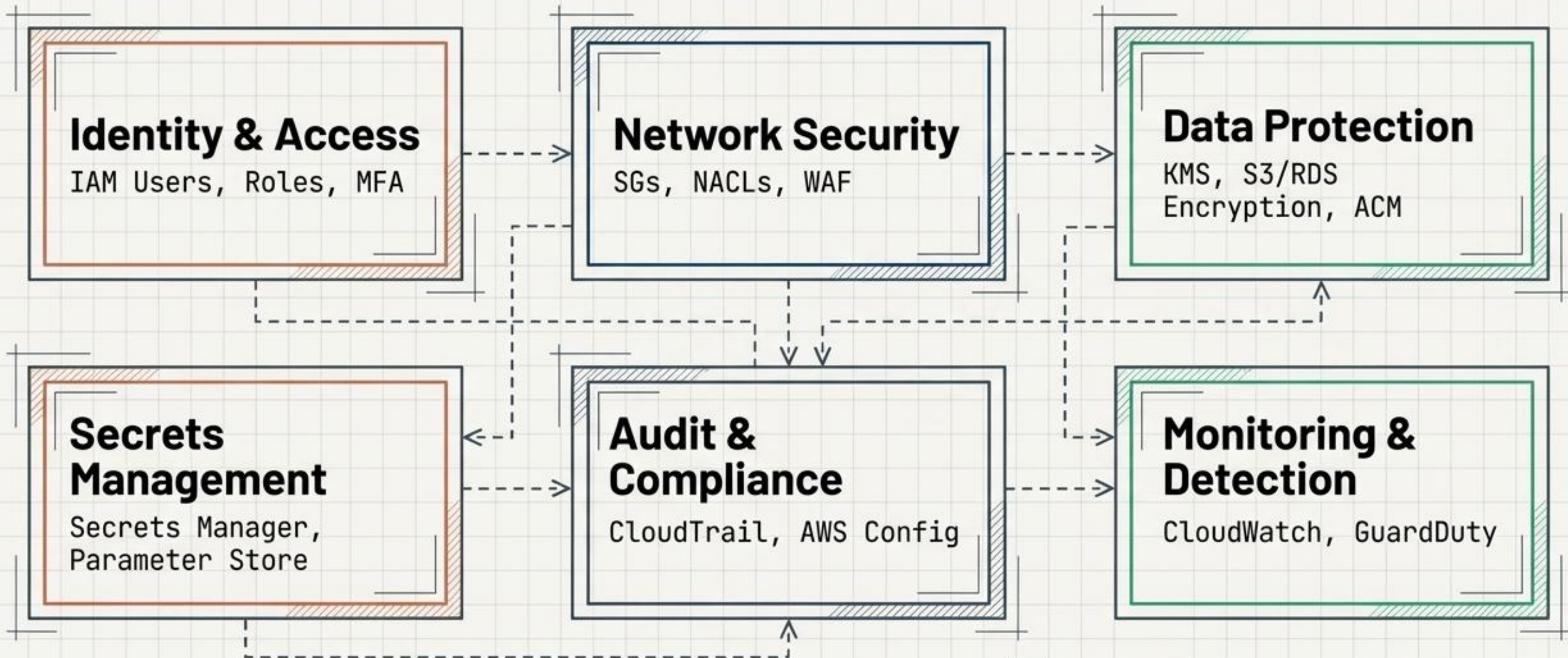
Coesão

Elementos com a mesma responsabilidade vivem juntos.

Baixo Acoplamento

Pacotes se comunicam por interfaces estritas, facilitando a evolução e manutenção (Princípios RUP/UP).

Arquitetura de Segurança SwiftTrack



A direção das setas define quem consome quem (Ex: Monitoring consome logs de Audit e tráfego de Network).

Zoom-In: Controle de Acesso Baseado em Papéis (RBAC)



Identities de máquina evitam credenciais fixadas no código.

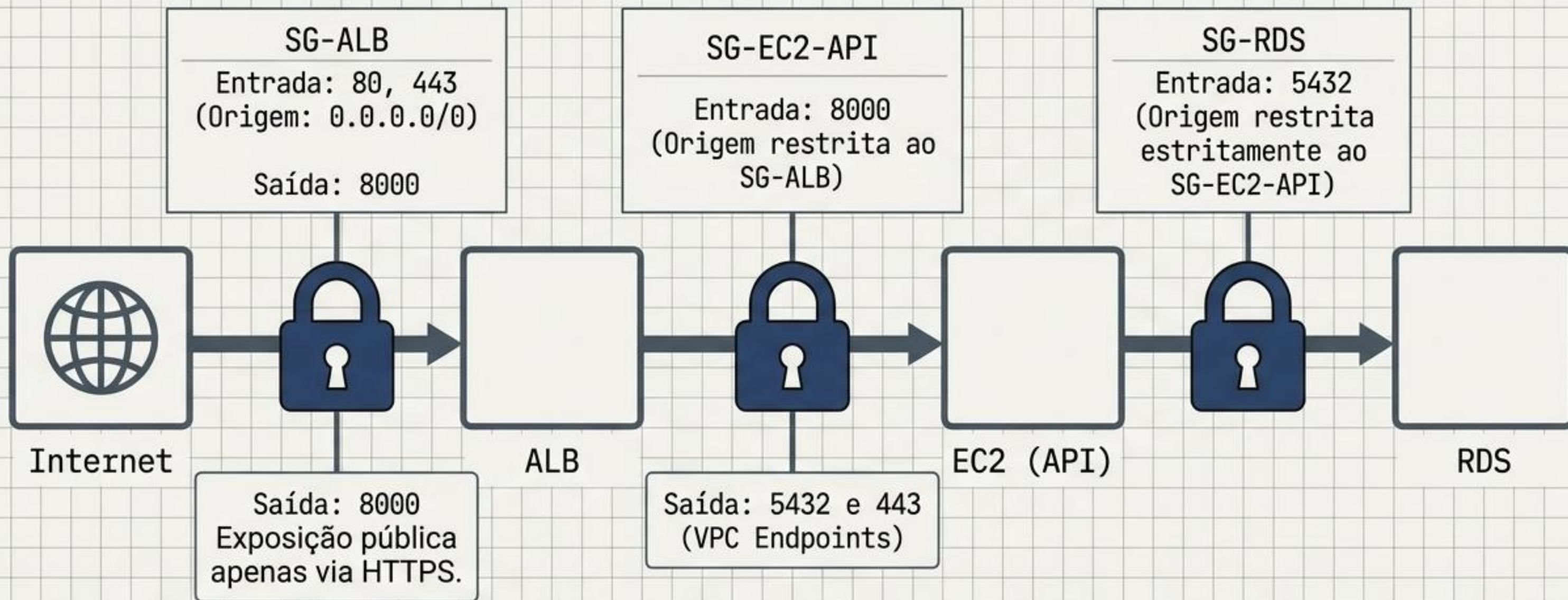
A anatomia do menor privilégio na prática

```
{  
  "Effect": "Allow",  
  "Action": [  
    "s3:GetObject",  
    "secretsmanager:GetSecretValue",  
    "dynamodb:PutItem"  
  ],  
  "Resource": "arn:aws:secretsmanager:us-east-1:123456789012:secret:rds-credentials-*"  
}
```

Limitação estrita à operação de leitura de imagens.

Restrição cirúrgica ao ARN exato. A máquina só lê a própria senha do banco, nada mais.

Zoom-In: 0 fluxo restrito de tráfego de rede



0 banco de dados nunca possui rota de entrada direta da internet.

Camadas de Defesa de Rede: SG vs. NACLs

Controle	Escopo de Atuação	Natureza da Regra	Exemplo SwiftTrack
Security Groups	Atua na Instância (Firewall do host)	Regras apenas de permissão (Allow)	SG-ALB liberando porta 80/443.
NACLs	Atua na Sub-rede (Firewall do perímetro)	Regras numeradas e de negação explícita (Deny)	NACL-Public Regra 100 (Allow TCP 80/443) e Regra final * (Deny All).

NACLs fornecem a camada de proteção bruta do perímetro;
SGs garantem o micro-isolamento entre serviços.

Zoom-In: Proteção de dados e conformidade LGPD (Art. 46)

Em Repouso



RDS (Dados Pessoais):

AES-256 via KMS Customer Managed Key.

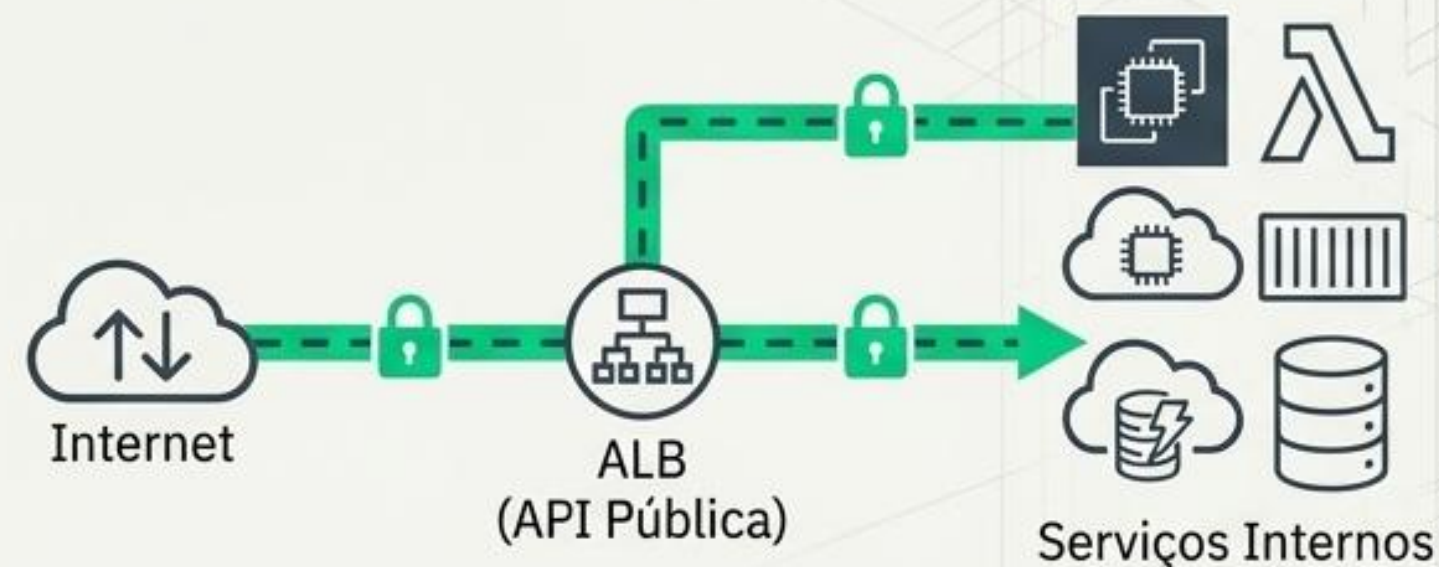
S3 (Comprovantes):

SSE-S3/KMS para proteção de mídia.

DynamoDB (Telemetria):

AES-256 via AWS Managed Key.

Em Trânsito



ALB (API Pública):

TLS 1.3 via certificados ACM.

Todos os serviços internos utilizando TLS em trânsito ponta a ponta.

Decisões arquiteturais exigem balanceamento técnico

Decisão 1: Criptografia KMS Total vs. Criptografia Apenas Sensíveis

 KMS Total Máxima proteção \$ ↑ +\$50/mês	Prós/Contras:	 Apenas Sensíveis Custo otimizado; Risco residual em dados classificados como não-sensíveis. \$ +\$20/mês
---	---------------	---

Decisão 2: Secrets Manager vs. Parameter Store

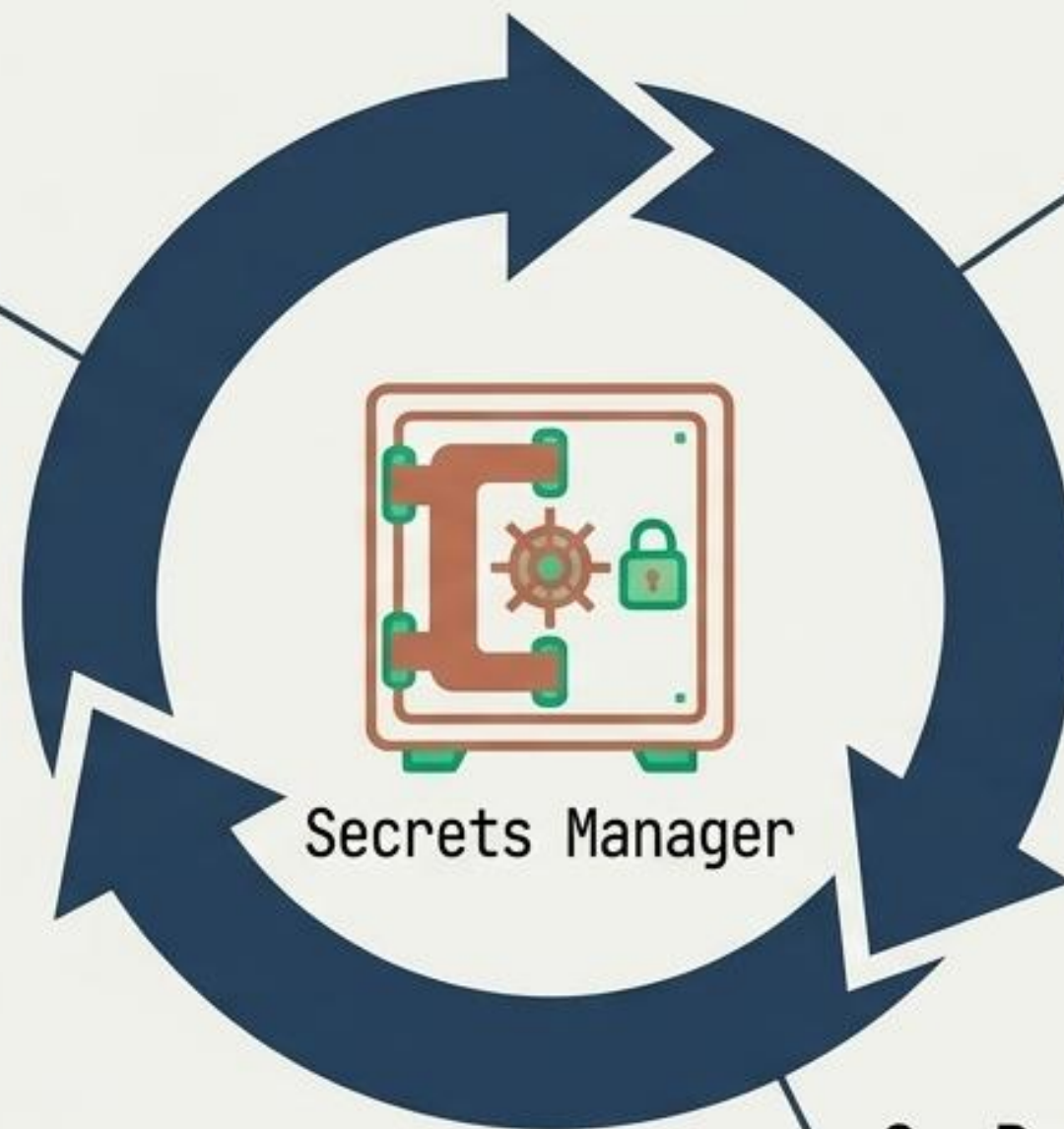
 Secrets Manager Rotação automática e segura nativa \$ \$0.40 por segredo/mês	Prós/Contras:	 Parameter Store Mais barato/sem rotação nativa. \$ \$0.00
---	---------------	--

Para a SwiftTrack, o custo de violação da LGPD torna os +\$50/mês da criptografia total o caminho obrigatório.

O Cofre de Segredos e o Rastro de Auditoria

3. Auditoria Imutável

CloudTrail e AWS Config registram toda invocação de `GetSecretValue`, garantindo trilha de auditoria inviolável.



1. Isolamento

Credenciais do RDS armazenadas como variáveis criptografadas.

2. Rotação Dinâmica



Secrets Manager altera a senha automaticamente a cada 90 dias, sem queda da aplicação.

Síntese Final: Matriz de Postura SwiftTrack

Ativo	Pacote AWS	Serviço	Risco Mitigado
Dados de Motoristas	 Data Protection	KMS + RDS	Multa LGPD / Vazamento.
Credenciais RDS	 Secrets Management	Secrets Manager	Credencial Hardcoded / Acesso indevido.
Logs de Acesso	 Audit & Compliance	CloudTrail	Impossibilidade de rastreabilidade forense.
API	 Identity & Access	IAM + MFA	Sequestro de conta privilegiada.

Próximos Passos: O Check-list de Entrega



Diagrama de Pacotes: Modelagem estrutural (PlantUML) conectando os 6 subsistemas de segurança.



Matriz de Firewall: Definição completa das portas e origens (SGs e NACLs).



Políticas IAM: Definição de Roles granulares seguindo o menor privilégio.



Memorial Descritivo: Documentação das decisões de Trade-off (Custo vs Risco).



A segurança robusta é desenhada antes da primeira linha de código ser escrita.